

Triagent: One-Pager für potenzielle Design-Partner

AI-unterstützte, on-prem-fähige Phishing-Triage für Security-Teams

Alexander Hülsmann und Tassilo Bechtolsheim – Produkt- und Prototyp-Stand April 2026

Worum es bei Triagent grundsätzlich geht

Triagent ist ein **Workspace für die Bearbeitung gemeldeter verdächtiger E-Mails**. Die Grundidee ist nicht, einen Analysten durch eine Black-Box-Klassifikation zu ersetzen. Die Grundidee ist, **manuelle Triage-Arbeit zu verkürzen**: gemeldete E-Mails schneller vorsortieren, technische Evidenz automatisch zusammenführen, einen ersten Entscheidungsentwurf liefern und daraus einen **nachvollziehbaren, exportierbaren Fall** machen.

Die größere Vision

Kurzfristig startet Triagent bei **reported-email triage**: also bei genau dem Moment, in dem Mitarbeiter oder Systeme verdächtige Mails melden und ein Analyst entscheiden muss, ob es sich um Phishing, Business Email Compromise, Malware, Spam oder einen harmlosen Fall handelt.

Mittelfristig soll daraus ein **lokal betreibbarer Evidence-Layer für E-Mail-Incidents** werden:

- automatische Trennung zwischen **analystenwürdigen Fällen** und **Low-Value-Meldungen**,
- konsistente Evidenzsammlung über Header, Auth, URLs, Anhänge und Message Source hinweg,
- AI-unterstützte Entwürfe für Klassifikation und Fallabschluss,
- später auch **kampagnenweises Arbeiten** statt mehrfacher Einzelfallprüfung ähnlicher Mails.

Welches Problem adressiert wird

- Reported Phishing ist in vielen Teams weiterhin **stark manuell**.
- Analysten springen zwischen Mail-Client, Header-/Auth-Checks, URL-Tools, Sandbox, Tickets und Dokumentation.
- Viel Aufwand steckt nicht nur in der Analyse, sondern in **Begründung, Auditierbarkeit und Export**.
- In regulierten oder sensiblen Umfeldern sind **Cloud-only-Workflows** oft organisatorisch oder datenschutzseitig schwierig.

Was im aktuellen Prototyp bereits funktioniert

- **Intake und Meldung**: Upload von `.eml` und `.msg` sowie Outlook-Add-in für das Melden aus dem Client.
- **Analysten-Workspace**: getrennte Sichten für Uploads als Intake-/Fallliste und In-tray als priorisierte Analysten-Queue.
- **Automatische Vorsortierung**: frühe Triage-Buckets wie **Needs investigation**, **Likely benign** und **Uncertain**. Dieser Teil ist **noch in einem sehr frühen Stadium** und muss vor produktivem Einsatz noch deutlich weiter getuned und validiert werden.
- **Technische Analyse**: SPF, DKIM, DMARC, ARC, Reply-To- und Return-Path-Signale, URL-Extraktion mit Redirect-Auflösung, Attachment-Metadaten, X-Headers, Transmission Hops und Raw Source.
- **AI-unterstützte Resolution**: früher Assist-Draft mit vorgeschlagener Disposition, Klassifikationscode und markierten Artefakten, immer analyst-in-the-loop. Auch dieser Teil ist aktuell **Demo- und Prototyp-Logik**, nicht schon produktionsreif.
- **Evidenz und Exporte**: PDF-, Markdown- und JSON-Export für Fallberichte sowie IOC-Export als JSON oder CSV.
- **Governance**: Audit Log, Rollen- und Rechtekonzept, API Keys und reproduzierbare Demo-Datensätze.

Was noch fehlt oder bewusst noch nicht als fertig gilt

- **Kein produktionsreifes Enterprise-Produkt**: der aktuelle Stand ist ein starker Demo- und Pilot-Prototyp.
- **Tiefe Integrationen** in Ticketing, SIEM, SOAR oder bestehende Mail-Security-Plattformen sind noch nicht fertig ausgebaut.
- **Enterprise SSO / IdP** und weitergehende Betriebs- und Packaging-Themen sind noch offen.
- **Kampagnen-Handling** ist im Backend angelegt, aber noch nicht der klar validierte Primär-Workflow.
- **Messbarer Kundennutzen** wie Zeitersparnis, Auto-Close-Raten oder Zahlungsbereitschaft muss noch in echten Pilot-Setups validiert werden.

Tech-Stack des Prototyps

- **Frontend**: Next.js, React, TypeScript
- **Backend**: FastAPI, Python
- **Datenhaltung**: PostgreSQL
- **ORM / Migrationen**: SQLAlchemy, Alembic
- **Artefakte / Storage**: MinIO als S3-kompatibler Objektspeicher
- **Deployment**: heute Docker Compose und self-hosted; perspektivisch sowohl **on-prem** als auch **Cloud** verfügbar
- **Client-Integration**: Outlook Add-in auf Basis von Office.js

Warum das für Design-Partner interessant sein kann

- Sie können früh beeinflussen, **welcher reale Triage-Workflow** zuerst sauber gelöst wird.
- Sie helfen zu validieren, **wo die größte Hebelwirkung liegt**: automatische Vorsortierung, schnellere Evidenzsammlung, sauberere Fallabschlüsse oder kampagnenweises Arbeiten.
- Sie bekommen früh Einblick in ein Tool, das **lokal betreibbar**, analystenorientiert und auf nachweisbare Entscheidungen ausgelegt ist.

Wonach aktuell gesucht wird

- Security-Teams, SOC's oder MSSP's mit wiederkehrendem reported-email-Volumen
- 30- bis 45-minütige Workflow-Gespräche oder ein gemeinsamer Blick auf synthetische / anonymisierte Beispielfälle
- perspektivisch 1 bis 3 Design-Partner, um einen klar abgegrenzten Pilot-Workflow zu testen

Kurz gesagt

Triagent ist heute **kein weiteres generisches "AI Security Tool"**, sondern ein konkreter Prototyp für **AI-unterstützte, evidence-first Phishing-Triage**. Der Kernwert liegt darin, Analysten **nicht jeden gemeldeten Fall gleich behandeln zu lassen**, sondern Low-Value-Meldungen von analystenwürdigen Fällen zu trennen und für die wichtigen Fälle schnell eine nachvollziehbare Entscheidungsgrundlage zu liefern.